Clase 10 · Análisis de vulnerabilidades, CVE/CVSS y ataques

Seguridad Informática Básica · Dra. Cintia Quezada Reyes · jueves 1 oct 2026 · Tema 2 (2.2, cierre) e inicio del Tema 3 · Apuntes y resumen de estudio

PARTE 1 · Apuntes completos

"Hasta aquí vendría el examen": con CVSS termina el temario del parcial (Temas 1 a 3 hasta CVSS).

2.2.1 Verificación periódica y reportes

- El análisis de vulnerabilidades es un proceso **continuo y documentado**: cada 6 meses o al menos una vez al año (como los análisis médicos: hoy negativo no garantiza mañana; en sistemas, una tecla cambia todo).
- Nunca un solo escaneo rápido de 5 minutos: varias pruebas sistemáticas para evitar falsos positivos y negativos.

> **Ética profesional**
> Jamás prometer **de palabra** que una empresa no tiene vulnerabilidades. Todo va en **reportes escritos**: qué pruebas, con qué metodología, qué resultados y qué limitaciones. Sin documento, el cliente puede culpar al consultor.

2.2.2 Tipos de análisis

Tipo	Qué hace	Ejemplo de clase
Estático	Observa el sistema en su modo habitual, sin ejecutar funciones activas, y lo compara contra baselines	Motor apagado en el taller
Dinámico	Evalúa en ejecución con cargas extremas o datos anómalos	Inscripciones UNAM en la primera hora; meter cuentas de titulados, mayúsculas/minúsculas, espacios extra, cortes de luz
Composición de software (SCA)	Revisa bibliotecas y dependencias	Programadores que incluyen 20 bibliotecas cuando necesitan una
Basado en red y niveles de confianza	Estado de SO, dispositivos y medios; asigna confianza alta/media/baja a hardware, software, procesos y personas (dinámica)	Switch nuevo mal configurado baja a bajo; empleado nuevo empieza bajo

Revisión de configuración	Compara parámetros contra buenas prácticas y líneas base	FileZilla agrega un espacio o "enter" invisible al final; sin activar "eliminar espacios finales" rechaza la conexión aunque la contraseña sea correcta

No casarse con un solo método.

2.2.3 Técnicas de escaneo

Técnica	Qué revisa
SAST (Static Application Security Testing)	El código fuente **sin ejecutarlo** (el libreto antes de actuar)
DAST (Dynamic Application Security Testing)	La aplicación **en ejecución**, por peticiones y respuestas (el ensayo con público)
SCA (Software Composition Analysis)	El árbol de dependencias: bibliotecas de terceros u obsoletas (el vestuario rentado)

Se conecta con DevSecOps. Error: depender solo de SAST.

2.2.4 CVE, NVD y CVSS

- **CVE** (Common Vulnerabilities and Exposures): identificador único de cada falla (su "CURP"): **CVE – año – número**, p. ej. CVE-2022-10001. Los números se reservan por bloques por organización. Los registros se mantienen aunque la tecnología sea vieja (empresas con UTP 5e de 100 Mbps que compran switches de 1000 Mbps inútiles).
- **NVD** (National Vulnerability Database del **NIST**, EE. UU.): detalles técnicos, parches e impacto de cada CVE.
- **CVSS** (Common Vulnerability Scoring System): severidad de 0.0 a 10.0.

Versión	Niveles
CVSS v2	3: Bajo, Mediano, Alto (verde, amarillo, rojo)
CVSS v3 / v4	4: **Bajo 0.1–3.9**, **Mediano 4.0–6.9**, **Alto 7.0–8.9** (naranja), **Crítico 9.0–10.0** (rojo). El 0.0 = sin vulnerabilidad

Al cliente no se le entrega solo un CVE o "severidad alta": se explica en lenguaje de negocio **qué proceso o área se afecta**. Errores: fuentes no verificadas (Facebook), confiar en la IA (inventa CVE), usar CVSS v2.

2.2.5 Ciberterrorismo

Difusión deliberada de información falsa o alarmista por medios digitales para **sembrar miedo** y dañar reputación, economía o salud. Ej.: "las vacunas COVID traen microchips"; "la carne de una cadena trae aditivos tóxicos". Su mecanismo principal es la manipulación psicológica, no atacar servidores.

3.0 Inicio del Tema 3: ataques

Definición de ataque

Un **ataque es la culminación de una amenaza**: todo lo que ya sucedió o está sucediendo y generó o genera un **daño severo al activo** (físico o lógico).

- **Bidireccionalidad físico-lógica:** lógico → físico (publicar fotos sensibles provoca un infarto por estrés); físico → lógico (alguien furioso publica datos privados para dañar a otro).
- Caso 11-S: una persona inventó ser sobreviviente; medios gastaron dinero y prestigio entrevistándola sin verificar.
- **No minimizar:** más del 50 % de las empresas que pagan un ransomware nunca reciben la clave; hay organizaciones con ransomware 10–20 veces al año por no corregir la raíz.

Prevención vs. recuperación

Recuperarse cuesta más que prevenir: tiempo, dinero, personal detenido, información perdida y confianza del cliente que cae a nula. Sismos 1985 vs. 2017: la prevención (simulacros, normas) redujo pérdidas, pero reingresar sin la revisión del DRO causó colapsos. En informática: respaldos planificados, servidores espejo, nube y capacitación (nada de contraseñas en post-its).

PARTE 2 · Resumen para estudiar

Versión corta de lo que más probablemente se pregunta. Léela primero y vuelve a la Parte 1 si algo no queda claro.

Análisis. Periódico y documentado por escrito. Tipos: estático, dinámico, SCA, de red (niveles de confianza dinámicos) y de configuración (FileZilla). SAST = código sin ejecutar; DAST = en ejecución; SCA = dependencias.

CVE / CVSS (examen)

CVE-año-número (identificador único); NVD = base del NIST. CVSS v3/v4: Bajo 0.1–3.9, Mediano 4.0–6.9, Alto 7.0–8.9, Crítico 9.0–10.0 (v2 tenía 3 niveles). Explicar el impacto en el negocio.

Ciberterrorismo. Desinformación para sembrar miedo.

Ataque. Culminación de una amenaza que genera daño severo; físico ↔ lógico. **Recuperar cuesta más que prevenir.**